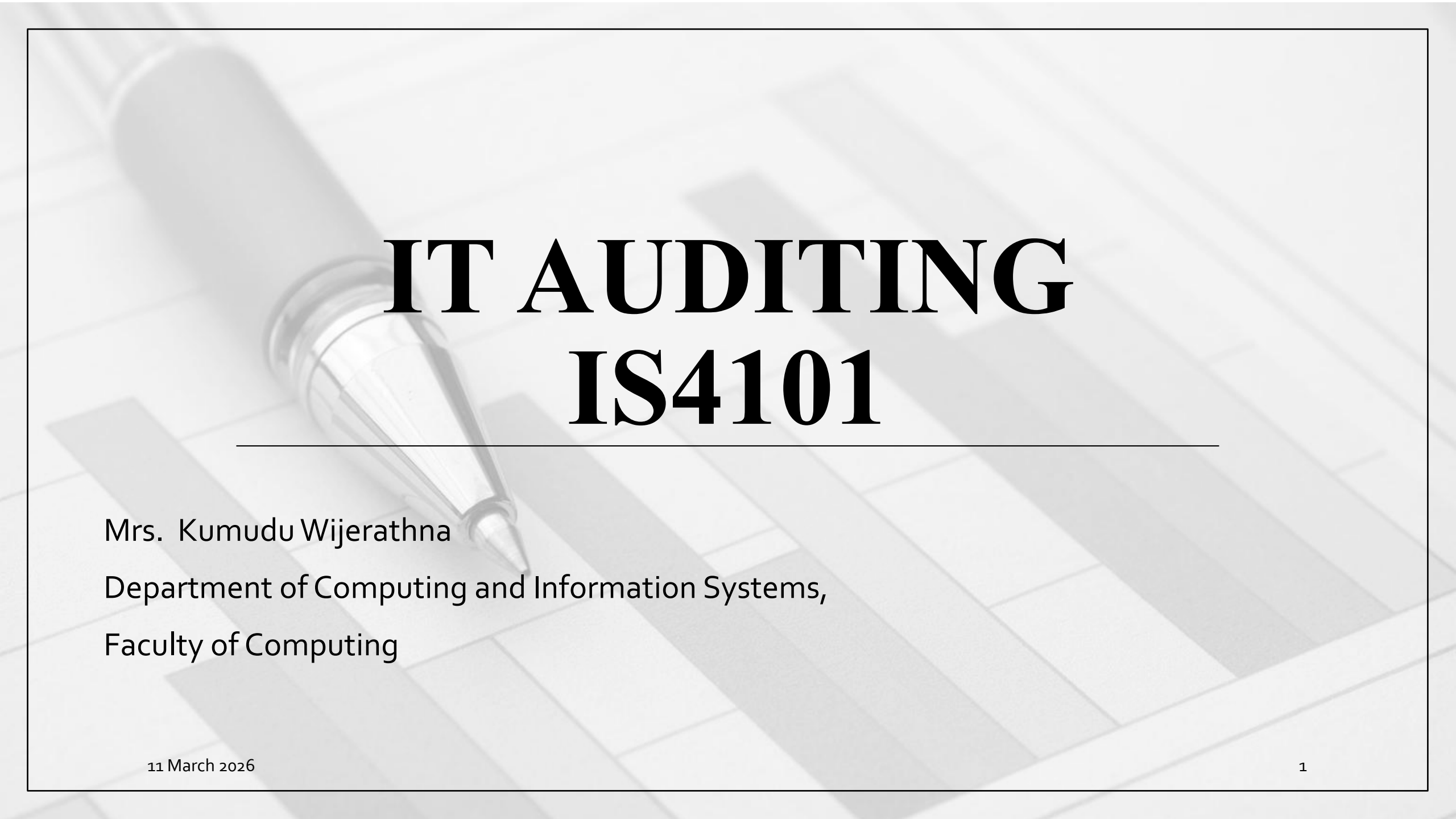


The background of the slide features a grayscale image of a silver pen resting on a document with a grid pattern, resembling a spreadsheet or accounting ledger. The pen is positioned diagonally from the top left towards the center.

IT AUDITING IS4101

Mrs. Kumudu Wijerathna
Department of Computing and Information Systems,
Faculty of Computing

Lesson Learning Outcome

By the end of this lesson, you will be able to,

- Understand the purpose of preventive, detective, and corrective controls
- Explain the importance of segregation of duties

Content

- IT Audit & Internal Controls
- PDC Model of Controls

IT Audit

- An IT audit focuses on the computer-based aspects of an organization's information system and modern systems employ significant levels of technology.

For example,

- Transaction processing is automated and performed in large part by computer programs.
- Similarly source documents, journals and ledgers that traditionally were paper-based are now digitized and stored in *relational databases*.

Internal controls

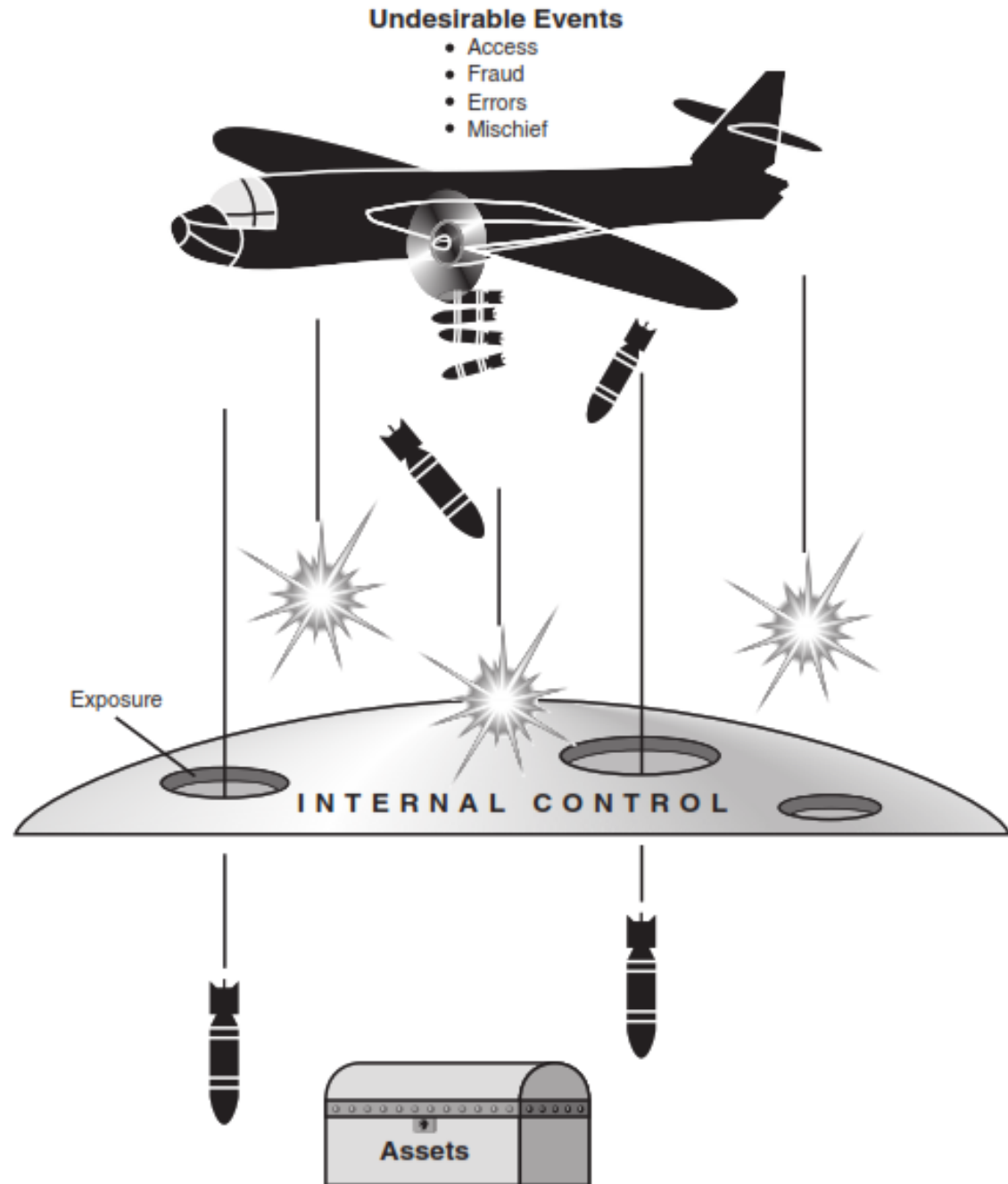
- Organization management is required by law to establish and maintain an adequate system of internal control.
- Refer for the knowledge,
 - SEC Acts of 1933 and 1934
 - Copyright Law 1976
 - Foreign Corrupt Practices Act of 1977
 - Committee of Sponsoring Organizations 1992
 - Sarbanes Oxley Act of 2002

Internal controls

- An organization's internal control system comprises policies, practices, and procedures to achieve **four broad objectives**,
 1. To **safeguard assets** of the firm
 2. To **ensure the accuracy and reliability** of accounting records and information
 3. To **promote efficiency** in the firm's operations
 4. To **measure compliance** with management's prescribed policies and procedures
- Refer COSO Internal Control Framework

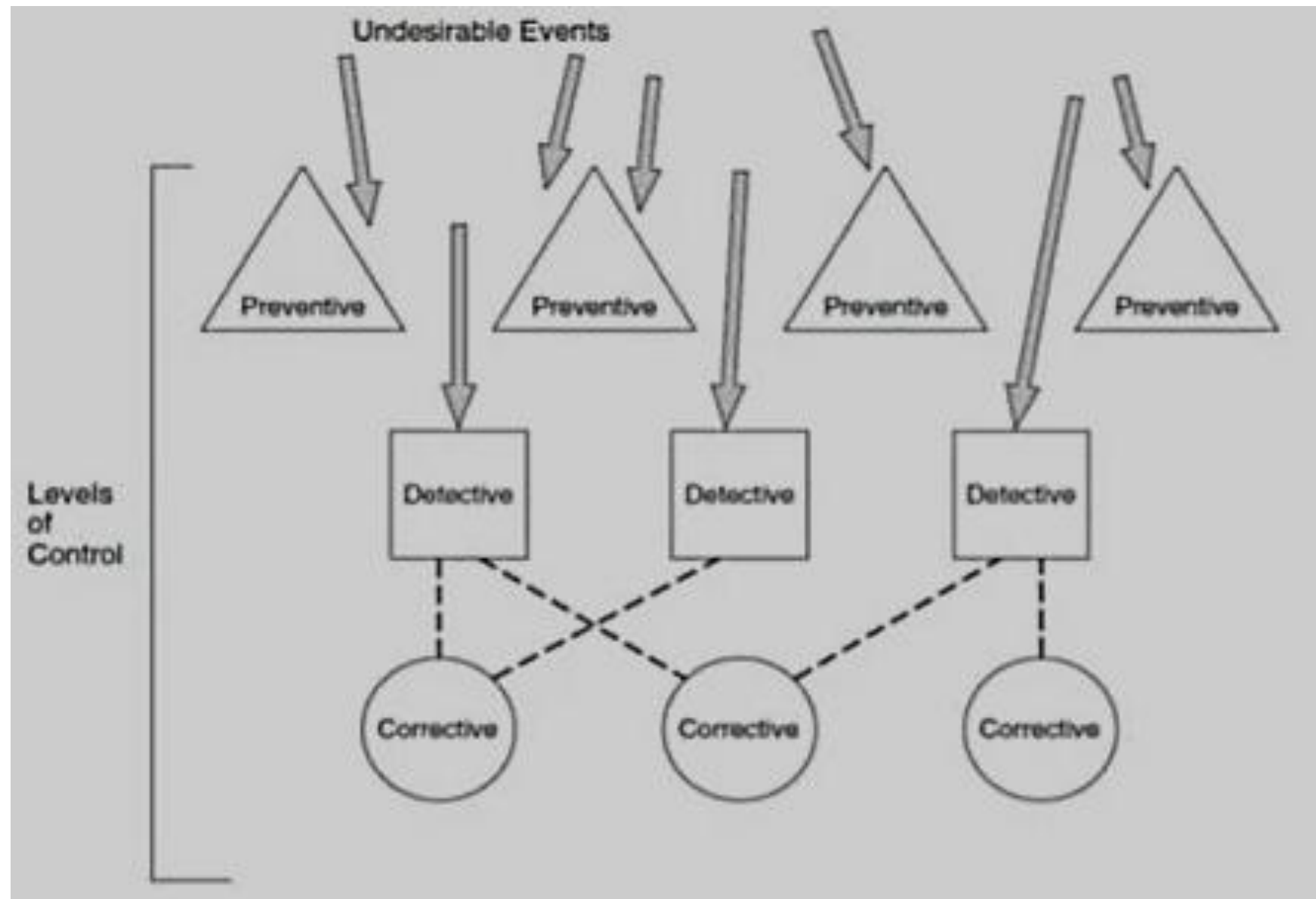
Internal controls

- Internal Control Shield



The PDC Model

- Internal control shield represented above actually consists of three levels of control
 - Preventive controls,
 - Detective controls,
 - Corrective controls



PDC – Preventive controls

- Prevention is the first line of defense in the control structure
- Preventive controls are **passive techniques** designed to **reduce the frequency of occurrence of undesirable events**
- Preventive controls force compliance with prescribed or desired actions and thus screen out aberrant (Undesired) events
- Preventing errors and fraud is far **more cost effective** than detecting and correcting problems after they occur.

PDC – Preventive controls

- Most undesirable events can be blocked at this first level,

For example,

- A well-designed data entry screen is an example of a preventive control
- The logical layout of the screen into zones that permit only specific types of data, such as customer name, address items sold, and quantity, forces the data entry clerk to enter the required data and prevents necessary data from being omitted

PDC – detective controls

- Detection of problems is the second line of defense
- Detective controls are devices, techniques, and procedures designed to identify and expose undesirable events that avoid preventive controls
- Detective controls reveal specific types of errors by comparing actual occurrences to preestablished standards

PDC – detective controls

- When the detective control identifies a departure from standard, it sounds an alarm to attract attention to the problem
- For example, assume that because of a data entry error, a customer sales order record contains the following data

Quantity	Unit Price	Total
10	\$10	\$1,000

- Before processing this transaction and posting to the accounts, a detective control should recalculate the total value using the price and quantity. Thus, this error above would be detected.

PDC – corrective controls

- Corrective actions must be taken to reverse the effects of detected errors.
- Detective controls identify undesirable events and draw attention to the problem corrective controls actually fix the problem.
- For any detected error, there may be more than one feasible corrective action, but the best course of action may not always be obvious.

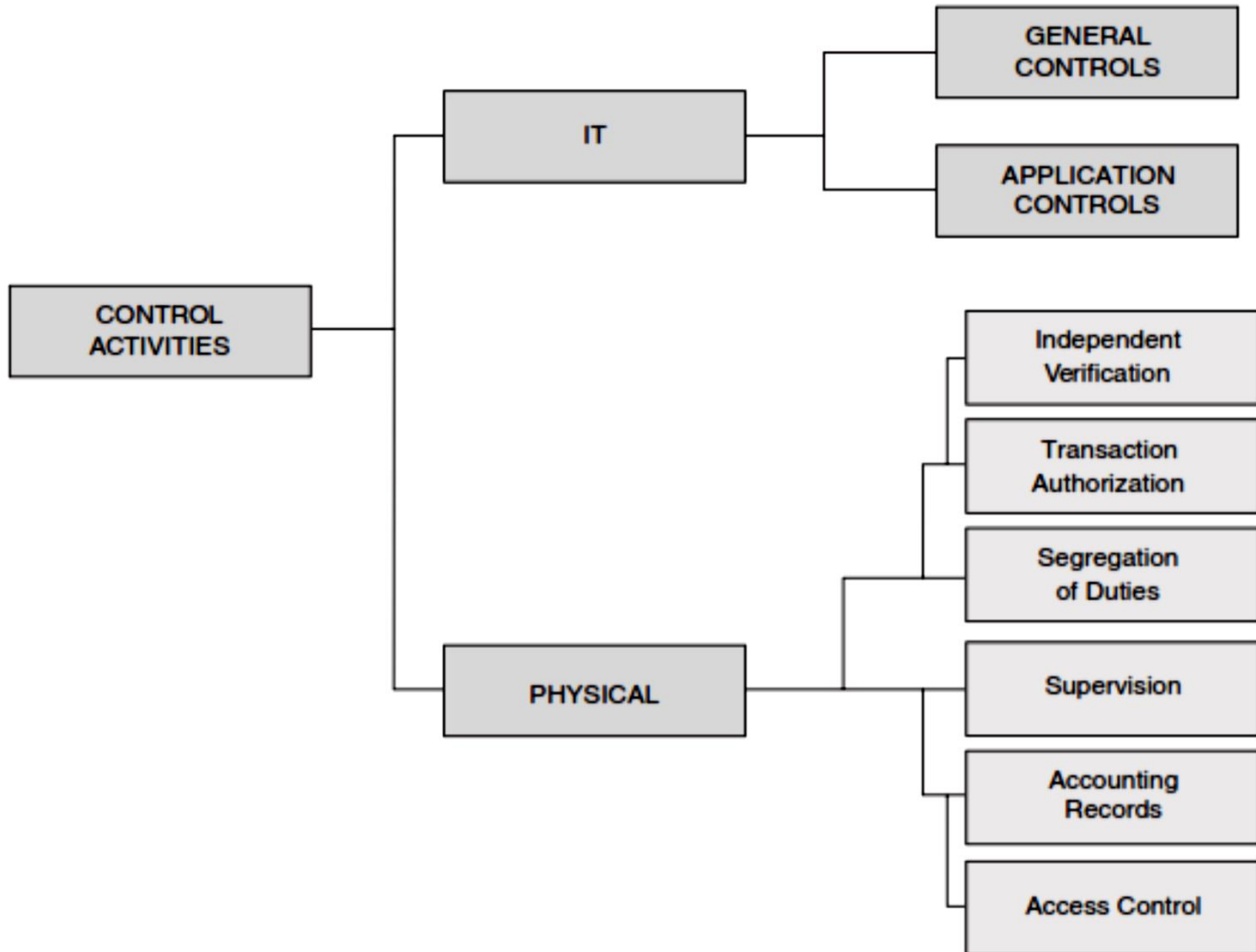
PDC – corrective controls

For example,

- In viewing the preceding error, your first inclination may have been to change the total value from 1 000 to 100 to correct the problem.
- This presumes that the quantity and price values in the record are correct they may not be.
- At this point, we cannot determine the real cause of the problem we know only that one exists.

Control Activities

- Control activities are the policies and procedures used to ensure that appropriate actions are taken to deal with the organization's identified risks
- Control activities can be grouped into two distinct categories;
 - a) Physical controls and
 - b) Information technology (IT) controls



(a) Physical controls

- This class of controls relates primarily to the human activities employed in accounting systems.
- These activities may be purely manual, such as the physical custody of assets, or they may involve the physical use of computers to record transactions or update accounts.
- Physical controls do not relate to the computer logic that performs accounting tasks.

Physical controls

- Rather they relate to the human activities that trigger and utilize the results of those tasks
- In other words,
 - physical controls focus on people but are not restricted to an environment in which clerks update paper accounts with pen and ink.

Physical controls

- Six categories of physical control activities

I. transaction authorization,

II. segregation of duties,

III. supervision

IV. accounting records,

V. access control,

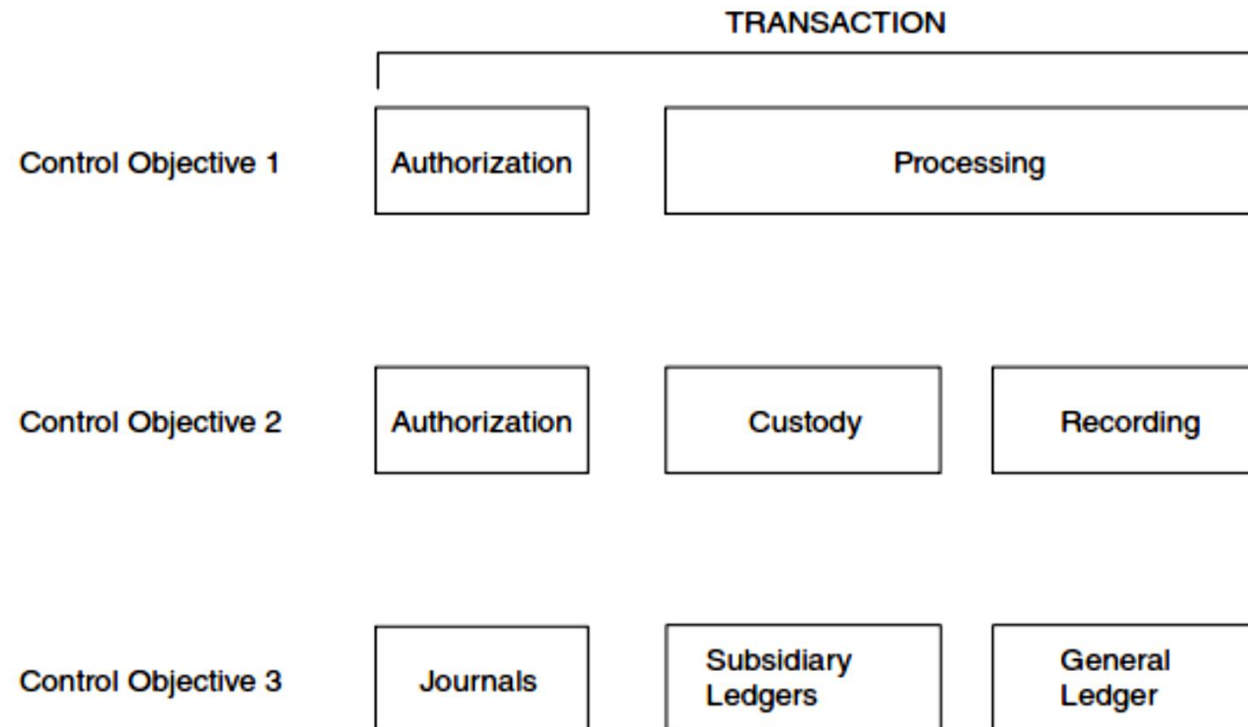
VI. independent verification

(ii) Segregation of duties

- One of the most important control activities is the segregation of employee duties to minimize incompatible functions
- Segregation of duties can take many forms, depending on the specific duties to be controlled

(ii) Segregation of duties

- However, the following three objectives provide general guidelines applicable to most organizations.



(ii) Segregation of duties

Objective 1

- The segregation of duties should be such that the authorization for a transaction is separate from the processing of the transaction
- For example, the purchasing department should not initiate purchases until the inventory control department gives authorization
- This separation of tasks is a control to prevent individuals from purchasing unnecessary inventory

(ii) Segregation of duties

Objective 2

- Responsibility for asset custody should be separate from the recordkeeping responsibility
- For example, the department that has physical custody of finished goods inventory (the warehouse) should not keep the official inventory records
- Accounting for finished goods inventory is performed by inventory control, an accounting function
- When a single individual or department has responsibility for both asset custody and record keeping, the potential for fraud exists
- Assets can be stolen or lost and the accounting records falsified to hide the event

(ii) Segregation of duties

Objective 3

- The organization should be structured so that a successful fraud requires collusion between two or more individuals with incompatible responsibilities
- For example, no individual should have sufficient access to accounting records to perpetrate a fraud
- Thus journals, subsidiary ledgers, and the general ledger are maintained separately
- For most people, the thought of approaching another employee with the proposal to collude in a fraud presents an insurmountable psychological barrier

(ii) Segregation of duties

Objective 3

- The fear of rejection and subsequent disciplinary action discourages solicitations of this sort.
- However, when employees with incompatible responsibilities work together daily in close quarters, the resulting familiarity tends to erode this barrier
- For this reason, the segregation of incompatible tasks should be physical as well as organizational
- Indeed, concern about personal familiarity on the job is the justification for establishing rules prohibiting nepotism

(B) IT Controls

- Information technology drives the financial reporting processes of modern organizations
- Automated systems initiate, authorize, record, and report the effects of financial transactions
- COSO identifies two broad groupings of IT controls
 - application controls and
 - general controls

Summary

- IT audit examines computerized systems
- Internal controls protect the organization and improve reliability
- PDC model ensures problems are prevented, detected, and corrected
- Proper segregation of duties reduces fraud risk
- Both physical and IT controls are essential in modern organizations

Thank you